

(a) Modelo de encuesta integral ISO/IEC 42001 – Ciberseguridad y Gestión de IA

0. Información general de la organización

1. Nombre de la organización (opcional).
2. Sector principal de actividad.
3. Tamaño de la organización (personas empleadas).
4. Volumen aproximado de facturación anual.
5. País/es en los que opera principalmente.
6. Rol de la persona que responde (CISO, CIO, DPO, Responsable de IA, etc.).
7. ¿Dispone la organización de un Sistema de Gestión de IA (AIMS) formalmente definido?
8. Sí, certificado conforme a ISO/IEC 42001.
9. Sí, alineado con ISO/IEC 42001 pero sin certificación.
10. Sí, basado en otros marcos (propio, NIST AI RMF, etc.).
11. No, pero se encuentra en diseño o planificación.
12. No, ni está previsto a corto plazo.

1. Estrategia, gobernanza y alcance del AIMS

1.1 ¿En qué medida la alta dirección ha aprobado formalmente la política de IA y de seguridad asociada a los sistemas de IA?

- Existe una política formal, aprobada y comunicada periódicamente.
- Existe una política formal pero con comunicación limitada.
- Existen directrices informales, no consolidadas en una política.
- No existe una política identificable.

1.2 ¿Se ha definido el alcance del AIMS incluyendo explícitamente los sistemas de IA críticos desde el punto de vista de ciberseguridad y continuidad de negocio?

- El alcance incluye todos los sistemas de IA relevantes y está documentado.
- El alcance incluye la mayoría de sistemas de IA relevantes.
- El alcance se limita a pilotos o casos de uso aislados.
- No se ha definido formalmente un alcance.

1.3 ¿Qué órganos de gobierno supervisan el desempeño del AIMS y sus indicadores de ciberseguridad?

- Comité específico de IA o comité de riesgos tecnológicos.
- Comité de seguridad de la información / ciberseguridad.
- Consejo de administración o equivalente.
- No existe un órgano específico; la supervisión es ad hoc.

1.4 ¿Con qué frecuencia se revisan los objetivos y métricas del AIMS relacionados con ciberseguridad?

- Trimestralmente o con mayor frecuencia.
- Semestralmente.
- Anualmente.

- De forma irregular, según circunstancias.
- No se revisan de forma sistemática.

1.5 ¿Se integran los indicadores del AIMS en los cuadros de mando corporativos (ej. riesgo operacional, ciberseguridad, cumplimiento)?

- Sí, plenamente integrados.
- Integrados parcialmente, para algunos sistemas de IA.
- Solo como informes específicos, fuera de los cuadros de mando principales.
- No, se gestionan de forma aislada.

2. Inventario de sistemas de IA y criticidad

2.1 ¿Dispone la organización de un inventario centralizado de sistemas de IA en producción?

- Sí, actualizado y completo.
- Sí, pero con lagunas o actualizaciones irregulares.
- Existe un inventario parcial o por áreas.
- No, o sólo existe de forma informal.

2.2 ¿Se clasifica la criticidad de los sistemas de IA considerando impacto en ciberseguridad, privacidad y continuidad?

- Sí, con un marco formal de clasificación y criterios documentados.
- Sí, pero con criterios poco homogéneos entre áreas.
- Se hace de forma cualitativa, caso por caso.
- No se clasifica la criticidad de forma explícita.

2.3 ¿Se registra para cada sistema de IA la siguiente información clave?

- Propietario/rol responsable.
- Modelo o arquitectura utilizada.
- Datos de entrenamiento y fuentes.
- Dependencias con terceros (APIs, modelos fundacionales, etc.).
- Controles de seguridad asociados.
- Ninguna de las anteriores se documenta sistemáticamente.

2.4 ¿Qué porcentaje aproximado de sistemas de IA en producción considera que están adecuadamente inventariados?

- Más del 90 %.
- Entre el 70 % y el 90 %.
- Entre el 40 % y el 70 %.
- Menos del 40 %.
- No se dispone de estimación.

3. Gestión de riesgos de IA y ciberseguridad

3.1 ¿Se realiza un análisis de riesgos específico para sistemas de IA, más allá del análisis general de TI/ciberseguridad?

- Sí, con metodología formal y criterios específicos.
- Sí, pero se reutiliza la metodología general sin adaptar.
- Se hace de forma ad hoc en proyectos críticos.
- No se realiza análisis de riesgos específico para IA.

3.2 ¿Con qué frecuencia se revisan y actualizan los riesgos de IA?

- Trimestralmente o con mayor frecuencia.
- Semestralmente.
- Anualmente.
- Solo al incorporar nuevos sistemas de IA.
- No existe un ciclo formal de revisión.

3.3 ¿Se evalúan explícitamente amenazas específicas de IA (prompt injection, data poisoning, modelo robbing, exfiltración vía modelo, etc.)?

- Sí, de forma sistemática en todos los sistemas de IA relevantes.
- Sí, pero solo en algunos sistemas de IA.
- Ocasionalmente, en pruebas o ejercicios aislados.
- No, estas amenazas no se tratan de forma diferenciada.

3.4 ¿Se documenta el riesgo residual de cada sistema de IA tras aplicar controles de seguridad?

- Sí, con niveles de riesgo residual aprobados por la dirección.
- Sí, pero sin aprobación formal.
- De forma parcial, solo en proyectos de mayor visibilidad.
- No se documenta el riesgo residual.

3.5 ¿Se integran los riesgos de IA en el mapa global de riesgos de la organización (ej. riesgo operacional, tecnológico, reputacional)?

- Sí, con métricas y umbrales definidos.
- Sí, pero sin métricas claras.
- De forma cualitativa, sin integración plena.
- No se integran explícitamente.

4. Datos, privacidad y seguridad de la información

4.1 ¿Se clasifican los datasets utilizados para entrenamiento, validación y prueba de sistemas de IA conforme a su sensibilidad?

- Sí, con un esquema de clasificación formal (p.ej. ENS, política interna).
- Sí, pero con aplicación desigual entre áreas.
- Solo para datos que ya estaban clasificados por otras razones.
- No se aplica clasificación específica.

4.2 ¿Se aplican medidas de anonimización o pseudonimización cuando procede, con evidencia de su efectividad?

- Sí, con revisiones y pruebas documentadas.

- Sí, pero sin evaluación formal de efectividad.
- Solo en casos aislados.
- No se aplican sistemáticamente.

4.3 ¿Los accesos a datos de entrenamiento y operación de IA están sometidos a controles de identidad y privilegio coherentes con los de otros sistemas críticos?

- Completamente alineados con los sistemas críticos.
- Parcialmente alineados, con excepciones.
- Controles ad hoc, no integrados con IAM corporativo.
- Control de accesos muy limitado o inexistente.

4.4 ¿Se monitorizan y registran accesos y usos de datos relacionados con IA (lectura, extracción masiva, exportación)?

- Sí, con logs centralizados y análisis periódico.
- Sí, pero sin análisis sistemático.
- Solo en entornos de producción, no en entornos de desarrollo.
- No se monitoriza de forma específica.

4.5 ¿Cómo se gestiona la retención y borrado de datos de IA (entrenamiento, logs, datos de prueba)?

- Políticas claras y automatizadas, alineadas con privacidad y normativa sectorial.
- Políticas definidas pero con ejecución manual.
- Criterios ad hoc por proyecto.
- No existen políticas claras.

5. Seguridad del ciclo de vida de los modelos (MLOps y equivalente)

5.1 ¿Dispone la organización de procesos formales para el desarrollo seguro de sistemas de IA (requisitos, pruebas, revisiones, controles de cambio)?

- Sí, integrados en un marco de desarrollo seguro.
- Sí, pero limitados a proyectos de gran relevancia.
- Procesos parcialmente definidos pero no sistemáticos.
- No, el desarrollo de IA se gestiona de forma artesanal.

5.2 ¿Se realizan pruebas de seguridad específicas en los modelos antes de su puesta en producción?

- Sí, con baterías predefinidas de pruebas de ataques y abusos.
- Sí, pero solo en proyectos seleccionados.
- Ocasionalmente, según disponibilidad del equipo.
- No se realizan pruebas de seguridad específicas.

5.3 ¿Se gestionan versiones, cambios y despliegues de modelos de IA con trazabilidad (quién, qué, cuándo, por qué)?

- Sí, con herramientas y procesos formalizados.
- Sí, pero con registros incompletos.

- Solo para algunos modelos.
- No existe gestión de versiones estructurada.

5.4 ¿Se definen criterios formales para aprobar el paso de un modelo a producción (go/no-go) que incluyan aspectos de seguridad?

- Sí, con checklists y umbrales cuantitativos.
- Sí, pero con criterios mayormente cualitativos.
- Decisiones caso por caso sin criterios claros.
- No existen criterios formales.

5.5 ¿Se mantiene un registro de incidentes, anomalías y “sorpresas” de los modelos en producción para retroalimentar el ciclo de mejora?

- Sí, con análisis periódico y acciones de mejora.
- Sí, pero sin análisis sistemático.
- Iniciativas aisladas o informales.
- No se mantiene dicho registro.

6. Monitorización, métricas y telemetría de IA

6.1 ¿Qué grado de monitorización continua tienen los sistemas de IA en producción?

- Monitorización completa (rendimiento, drift, seguridad, uso, abuso).
- Monitorización parcial, centrada en rendimiento funcional.
- Monitorización limitada a disponibilidad técnica.
- No existe monitorización continua.

6.2 ¿Se han definido KPIs específicos para sistemas de IA relacionados con ciberseguridad (incidentes, vulnerabilidades, intentos de abuso, etc.)?

- Sí, para la mayoría de sistemas de IA.
- Sí, pero solo para sistemas críticos.
- Algunos KPIs aislados, sin marco coherente.
- No se han definido KPIs específicos.

6.3 ¿Con qué frecuencia se revisan los KPIs de ciberseguridad asociados a IA?

- Semanalmente.
- Mensualmente.
- Trimestralmente.
- De forma irregular.
- No se revisan.

6.4 ¿Se detecta y gestiona la deriva de modelos (drift) como un riesgo de seguridad y no sólo de precisión?

- Sí, con umbrales y planes de acción definidos.
- Sí, pero sin vincularlo explícitamente a seguridad.

- De forma ad hoc cuando se detectan problemas.
- No se gestiona de forma explícita.

6.5 ¿Se registran y analizan activamente intentos de abuso de los sistemas de IA (prompt injection, extracción de datos, etc.)?

- Sí, con telemetría específica y análisis regular.
- Sí, pero sin análisis sistemático.
- Solo en incidentes graves.
- No se registran de forma diferenciada.

7. Gestión de incidentes y respuesta ante IA

7.1 ¿Existen procedimientos específicos de gestión de incidentes que contemplen incidentes relacionados con IA?

- Sí, integrados en el proceso general de respuesta.
- Sí, pero como anexos o guías complementarias.
- Se improvisa caso por caso.
- No existe consideración específica.

7.2 ¿Se miden tiempos de detección, contención y recuperación de incidentes en sistemas de IA?

- Sí, con métricas comparables a otros sistemas críticos.
- Sí, pero sólo para algunos incidentes.
- Datos de tiempos disponibles pero sin métricas formales.
- No se miden.

7.3 ¿Se realizan simulacros o ejercicios (tabletop, red teaming) que incluyan escenarios de ataque o fallo de sistemas de IA?

- Sí, al menos una vez al año.
- Sí, pero de forma ocasional.
- En preparación.
- No se realizan.

7.4 ¿Se documentan lecciones aprendidas específicas de incidentes en IA y se incorporan al AIMS?

- Sí, con procesos claros de retroalimentación.
- Sí, pero de forma irregular.
- Solo en incidentes de alto impacto.
- No se documentan.

7.5 ¿Cómo valora la relación entre el equipo de IA y el equipo de ciberseguridad en la gestión de incidentes?

- Coordinación fluida y roles bien definidos.
- Coordinación razonable con áreas de mejora.
- Colaboración esporádica y reactiva.
- Relación mínima o inexistente.

8. Terceros, cadena de suministro y servicios de IA externos

8.1 ¿Se evalúan los proveedores de IA (APIs, modelos fundacionales, SaaS, etc.) con criterios específicos de seguridad y cumplimiento?

- Sí, con un proceso formal de homologación.
- Sí, pero con criterios aún inmaduros.
- Evaluaciones básicas centradas en aspectos contractuales.
- No se realiza evaluación específica.

8.2 ¿Los contratos con proveedores de IA incluyen cláusulas sobre seguridad, gestión de incidentes, continuidad y derecho de auditoría?

- Sí, de forma sistemática.
- Sí, pero con variaciones significativas.
- Solo en casos puntuales.
- No, o muy raramente.

8.3 ¿Se monitorizan incidentes y vulnerabilidades asociados a terceros de IA?

- Sí, con registros y análisis dedicados.
- Sí, pero sin análisis estructurado.
- Solo cuando el incidente es grave y visible.
- No se monitorizan de forma específica.

8.4 ¿Se dispone de planes de contingencia (p.ej. cambio de proveedor, degradación controlada) para fallos o incidentes graves en servicios de IA externos?

- Sí, documentados y probados.
- Sí, documentados pero no probados.
- Planes parciales o implícitos.
- No existen planes de contingencia específicos.

8.5 ¿Se conoce y gestiona la cadena de suministro de IA (subproveedores, datos, infraestructuras subyacentes)?

- Sí, con visibilidad razonable y mapas de dependencia.
- Visibilidad parcial, con lagunas importantes.
- Escasa visibilidad, muy dependiente del proveedor directo.
- No se dispone de información.

9. Personas, cultura y capacidades

9.1 ¿Qué grado de formación tienen las personas clave (IA, MLOps, ciberseguridad, negocio) en riesgos y seguridad de IA?

- Formación estructurada anual, con contenidos específicos.
- Formación ocasional o puntual.
- Formación informal o basada en autoestudio.
- Prácticamente inexistente.

9.2 ¿Se sensibiliza a usuarios finales sobre el uso seguro de sistemas de IA (límites, riesgos, información que no debe introducirse, etc.)?

- Sí, con campañas regulares y materiales claros.
- Sí, pero de forma esporádica.
- Limitado a usuarios muy específicos.
- No se realiza.

9.3 ¿Existen roles explícitos (p.ej. Responsable de IA, Comité de Ética de IA, etc.) con mandato sobre IA y seguridad?

- Sí, con funciones definidas y operativas.
- Sí, pero con funciones difusas.
- Roles de facto, no formalizados.
- No existen roles específicos.

9.4 ¿Se promueve una cultura en la que reportar problemas o dudas sobre sistemas de IA sea valorado y no penalizado?

- Sí, con canales visibles y sin represalias.
- Sí, pero los canales no son muy utilizados.
- Depende mucho de las áreas o mandos.
- No se percibe tal cultura.

9.5 ¿Cómo describiría el nivel global de madurez en IA segura de su organización?

- Alto: IA integrada con controles robustos y medidos.
- Medio: IA extendida con controles en evolución.
- Bajo: IA experimental con control limitado.
- Muy bajo: IA incipiente sin marco de seguridad.

10. Indicadores, IGM y retorno de inversión

10.1 ¿Dispone la organización de un conjunto documentado de indicadores de gestión de IA (IGM) que incluya métricas de ciberseguridad?

- Sí, formalmente documentado y aprobado.
- Sí, en proceso de formalización.
- Indicadores dispersos sin marco unificado.
- No existe un IGM definido.

10.2 ¿Se cuantifica el impacto económico de incidentes o fallos relacionados con IA (pérdidas, sanciones, costes de recuperación)?

- Sí, con metodología consistente.
- Sí, pero de forma aproximada.
- Ocasionalmente, en incidentes destacados.
- No se cuantifica.

10.3 ¿Se realiza alguna forma de análisis del retorno de inversión (ROI) de las iniciativas de gobierno y seguridad de IA?

- Sí, con modelos cuantitativos de coste/beneficio.
- Sí, pero de forma cualitativa o semi-cuantitativa.
- Se perciben beneficios pero no se miden.
- No se realiza análisis de ROI.

10.4 ¿Se utilizan indicadores de desempeño del AIMS (p.ej. reducción de incidentes, tiempos de respuesta, mejora de cumplimiento) en decisiones de inversión y priorización?

- Sí, como insumo clave.
- Sí, pero junto a otros criterios predominantes.
- Raramente.
- No se consideran.

10.5 ¿Cuál es la principal motivación de su organización para avanzar en la madurez de ISO 42001 y la seguridad de IA?

- Cumplimiento normativo y regulatorio.
- Protección de reputación y confianza.
- Eficiencia operativa y calidad del servicio.
- Ventaja competitiva e innovación.
- Otra (especificar).